

GCP FULL SECURITY AUDIT

IAM • Firewall & VPC • Security Command Center

Prepared By	Sanivarapu Subbalakshmi
College	SRKR Engineering College, Bhimavaram
Certification	Google Cloud Cybersecurity Certificate — Google
Date	23 / 06 / 2026
Audit Method	Alternative Method — flaws.cloud + Nmap
Tools Used	flaws.cloud, Nmap, Kali Linux, Browser
Audit Scope	IAM Misconfiguration + Firewall / Port Audit + Cloud Security Findings
Report Version	v1.0

1. OBJECTIVE

This project conducts a comprehensive cloud security audit across three critical domains — Identity and Access Management (IAM), Network Firewall Rules, and Security Command Center findings. The audit simulates the work of a Cloud Security Analyst performing a routine security posture review, using industry-standard free tools that map directly to GCP equivalents.

- Audit IAM policies to identify overpermissioned users, public bucket access, and exposed credentials that violate the principle of least privilege
- Review network firewall rules to identify dangerous open ports and unrestricted ingress rules that expose systems to external threats
- Use automated cloud security scanning to detect misconfigurations, vulnerabilities, and threats across cloud resources
- Document all findings with severity ratings and recommend remediation steps
- Demonstrate real-world cloud security analyst skills through hands-on investigation using flaws.cloud, Nmap, and Kali Linux

2. ENVIRONMENT & SETUP

Cloud Platform	Google Cloud Platform (GCP) — concepts applied via equivalent tools
IAM Audit Tool	flaws.cloud — intentionally misconfigured cloud lab by Scott Piper
Firewall Audit Tool	Nmap (Network Mapper) — industry-standard port scanner
Operating System	Kali Linux (VM) + Windows Host
Audit Region	Andhra Pradesh, India
Account Type	Free — no payment required for any tool used
Audit Areas	IAM • VPC Firewall Rules • Security Command Center
Audit Date	23 June 2026

All tools used in this audit are free and open-source. flaws.cloud is a deliberately vulnerable AWS environment used globally for cloud security training. Nmap is used daily by SOC analysts and penetration testers worldwide. The security concepts, findings, and remediation steps demonstrated here are directly equivalent to those performed in GCP Console.

3. PART 1 — IAM SECURITY AUDIT

Identity and Access Management (IAM) controls who has access to what resources in GCP. Overpermissioned IAM roles are the leading cause of cloud data breaches — the Snowflake 2024 breach affecting 165 organisations was largely caused by IAM misconfigurations. This audit used flaws.cloud, an intentionally misconfigured AWS cloud environment, to identify and document real IAM vulnerabilities.

3.1 Finding 1 — Public S3/GCS Bucket (Level 1)

What was found: The S3 bucket flaws.cloud was configured with public read access, allowing anyone on the internet to list all files and download their contents without providing any credentials. This is the equivalent of a GCP Cloud Storage bucket with allUsers granted roles/storage.objectViewer.

How it was discovered: Navigating directly to the bucket URL in a browser returned the 'Congrats! You found the secret file!' confirmation page, proving the bucket contents were fully accessible without any authentication.



Figure 1 — flaws.cloud Level 1: Secret file accessed without authentication — confirms public bucket misconfiguration

3.2 Finding 2 — Overpermissioned IAM Policy (Level 2)

What was found: The Level 2 bucket was configured to allow access by any authenticated AWS user — meaning any of the millions of AWS accounts worldwide could read its contents. This is the equivalent of granting roles/storage.objectViewer to allAuthenticatedUsers in GCP. The Kali Linux terminal confirmed this by showing an Access Denied error when accessing without credentials — but access was granted with any valid AWS account.

```
(kali@kali)~$ aws s3 ls s3://level2-c8b217a33fcf1f839f6f1f73a00a9ae7.flaws.cloud --no-sign-request
An error occurred (AccessDenied) when calling the ListObjectsV2 operation: Access Denied
```

Figure 2 — Kali Linux terminal: Access Denied without credentials confirms bucket requires authentication but not specific authorisation

3.3 Finding 3 — Credentials Exposed in Git History (Level 3)

What was found: The Level 3 bucket contained a .git directory that was accidentally made public. The bucket XML listing revealed .git/COMMIT_EDITMSG, .git/HEAD, .git/config and other git objects — all publicly readable. Examining the git commit history revealed that AWS IAM access keys had been committed and then deleted, but remained fully recoverable from git history.

```

▼ <ListBucketResult xmlns="http://s3.amazonaws.com/doc/2006-03-01/">
  <Name>level3-9afd3927f195e10225021a578e6f78df.flaws.cloud</Name>
  <Prefix/>
  <Marker/>
  <MaxKeys>1000</MaxKeys>
  <IsTruncated>false</IsTruncated>
  ▼ <Contents>
    <Key>.git/COMMIT_EDITMSG</Key>
    <LastModified>2017-09-17T15:12:24.000Z</LastModified>
    <ETag>"5f8f2cb9c2664a23f08dd8a070ae7427"</ETag>
    <Size>52</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
  ▼ <Contents>
    <Key>.git/HEAD</Key>
    <LastModified>2017-09-17T15:12:24.000Z</LastModified>
    <ETag>"4cf2d64e44205fe628ddd534e1151b58"</ETag>
    <Size>23</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
  ▼ <Contents>
    <Key>.git/config</Key>
    <LastModified>2017-09-17T15:12:24.000Z</LastModified>
    <ETag>"920a11de313bfb8d93d81f4a3a5b71b6"</ETag>
    <Size>130</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
  ▼ <Contents>
    <Key>.git/description</Key>
    <LastModified>2017-09-17T15:12:24.000Z</LastModified>
    <ETag>"a0a7c3fff21f2aea3cfa1d0316dd816c"</ETag>
    <Size>73</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>

```

Figure 3 — flaws.cloud Level 3: Public bucket XML listing showing .git directory files exposed — credentials recoverable from git history



Level 3: Hint 3

You should have found the AWS key and secret. You can configure your aws command to use it and create a profile for it using:

```
aws configure --profile flaws
```

Then to list S3 buckets using that profile run:

```
aws --profile flaws s3 ls
```

Want to just find out where the next level is? Go to [Hint 4](#)

Figure 4 — Level 3 Hint 3: Confirming AWS credentials found in git history and how to use them

3.4 IAM Findings Summary

Principal / Resource	Misconfiguration Found	Access Level	Risk Level	Follows Least Privilege?
flaws.cloud S3 Bucket — s3://flaws.cloud	Bucket publicly accessible without any authentication — entire contents readable by anyone	Anonymous / allUsers read access	CRITICAL	No — public read access violates least privilege. Bucket should be private with specific IAM grants.
flaws.cloud Level 2 — Authenticated AWS IAM	Bucket readable by any authenticated AWS user — not restricted to specific accounts or roles	Any AWS account — overpermissioned IAM policy	CRITICAL	No — IAM policy grants access to all 1M+ AWS accounts instead of specific principals.
flaws.cloud Level 3 — Git Repository / IAM Keys	AWS IAM credentials accidentally committed to git history — keys retrievable without any permissions	Full AWS account access via leaked keys	CRITICAL	No — credentials must never be stored in code or git history. Use Secrets Manager.

3.5 IAM Misconfigurations — Detailed Analysis

#	Misconfiguration	Severity	Evidence	Recommended Fix
1	S3/GCS bucket configured with public read access — allUsers can list and download all files without authentication	CRITICAL	flaws.cloud Level 1 — XML bucket listing visible in browser with no credentials. Files including secret-dd02c7c.html exposed.	Set bucket ACL to private. Remove allUsers and allAuthenticatedUsers from bucket IAM policy. Use specific service account grants with roles/storage.objectViewer scoped to required principals only.
2	IAM policy grants bucket access to all authenticated AWS users — 1M+ accounts — instead of specific principals	CRITICAL	flaws.cloud Level 2 — bucket accessible using any valid AWS credentials, not just the owner's.	Replace broad AuthenticatedUsers grants with specific principal ARNs or service account emails. Apply principle of least privilege — grant only to the exact identities that need access.
3	AWS IAM access keys accidentally committed to git repository and left in git history — recoverable even after deletion from code	CRITICAL	flaws.cloud Level 3 — .git directory synced to public bucket. git log reveals commit where keys were added then removed.	Never commit credentials to git. Use .gitignore for credential files. Rotate any exposed keys immediately. Use GCP Secret Manager or AWS Secrets Manager for all credentials. Enable git-secrets pre-commit hooks.

4. PART 2 — VPC FIREWALL RULE AUDIT

VPC Firewall Rules control what network traffic can enter and leave your GCP project. Open firewall rules exposing SSH (port 22) or RDP (port 3389) to the entire internet are one of the most dangerous and common misconfigurations — they directly enable automated brute force attacks. This audit documents both observed network findings and GCP-equivalent firewall rule scenarios.

4.1 Network Port Scan — Kali Linux VM (Nmap)

Tool used: Nmap 7.95 — industry standard port scanner used by SOC analysts worldwide

Network scanned: 192.168.11.0/24 — 256 addresses, 4 hosts discovered

Commands run: `ip route → nmap -sV 192.168.11.2 → nmap -sV 192.168.11.0/24 -oN nmap_results.txt → cat nmap_results.txt`

```
(kali㉿kali)-[~]
$ ip route
default via 192.168.11.2 dev eth0 proto dhcp src 192.168.11.128 metric 100
192.168.11.0/24 dev eth0 proto kernel scope link src 192.168.11.128 metric 100

(kali㉿kali)-[~]
$ nmap -sV 192.168.11.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-23 05:42 EDT
Nmap scan report for 192.168.11.2
Host is up (0.000088s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
53/tcp    open  domain  dnsmasq
MAC Address: 00:50:56:E9:75:52 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.64 seconds

(kali㉿kali)-[~]
$ nmap -sV 192.168.11.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-23 05:43 EDT
Nmap scan report for 192.168.11.1
Host is up (0.0011s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
7070/tcp  open  ssl/realserver?
MAC Address: 00:50:56:C0:00:08 (VMware)

Nmap scan report for 192.168.11.2
Host is up (0.00024s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
53/tcp    open  domain  dnsmasq
MAC Address: 00:50:56:E9:75:52 (VMware)

Nmap scan report for 192.168.11.254
Host is up (0.00039s latency).
All 1000 scanned ports on 192.168.11.254 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:50:56:E6:B1:42 (VMware)

Nmap scan report for 192.168.11.128
Host is up (0.0000070s latency).
All 1000 scanned ports on 192.168.11.128 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
```

Figure 5 — Kali Linux: `ip route` showing gateway 192.168.11.2, then `nmap -sV` scan revealing open ports 53/tcp (dnsmasq) and 7070/tcp (ssl/realserver)

```

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (4 hosts up) scanned in 20.13 seconds

(kali@kali)-[~]
$ nmap -sV 192.168.11.0/24 -oN nmap_results.txt
cat nmap_results.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-23 05:43 EDT
Nmap scan report for 192.168.11.1
Host is up (0.0051s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
7070/tcp open  ssl/realserver?
MAC Address: 00:50:56:C0:00:08 (VMware)

Nmap scan report for 192.168.11.2
Host is up (0.00025s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp open  domain dnsmasq
MAC Address: 00:50:56:E9:75:52 (VMware)

Nmap scan report for 192.168.11.254
Host is up (0.00033s latency).
All 1000 scanned ports on 192.168.11.254 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:50:56:E6:B1:42 (VMware)

Nmap scan report for 192.168.11.128
Host is up (0.0000050s latency).
All 1000 scanned ports on 192.168.11.128 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (4 hosts up) scanned in 27.16 seconds
# Nmap 7.95 scan initiated Tue Jun 23 05:43:48 2026 as: /usr/lib/nmap/nmap --privileged -sV -oN nmap_results.txt 192.168.11.0/24
Nmap scan report for 192.168.11.1
Host is up (0.0051s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
7070/tcp open  ssl/realserver?
MAC Address: 00:50:56:C0:00:08 (VMware)

Nmap scan report for 192.168.11.2
Host is up (0.00025s latency).

```

Figure 6 — Nmap full network scan (192.168.11.0/24) saved to file and output via cat — 4 hosts discovered, ports 53 and 7070 open

```

Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
7070/tcp open  ssl/realserver?
MAC Address: 00:50:56:C0:00:08 (VMware)

Nmap scan report for 192.168.11.2
Host is up (0.00025s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp open  domain dnsmasq
MAC Address: 00:50:56:E9:75:52 (VMware)

Nmap scan report for 192.168.11.254
Host is up (0.00033s latency).
All 1000 scanned ports on 192.168.11.254 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:50:56:E6:B1:42 (VMware)

Nmap scan report for 192.168.11.128
Host is up (0.0000050s latency).
All 1000 scanned ports on 192.168.11.128 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Tue Jun 23 05:44:15 2026 -- 256 IP addresses (4 hosts up) scanned in 27.16 seconds

```

Figure 7 — Nmap scan completion: 256 addresses scanned, 4 hosts up, full port details confirmed

4.2 Firewall Findings — Full Analysis

Rule / Device	Direction	Source Range	Port(s)	Action	Risk Level	Finding
192.168.11.1 — VMware Host / Gateway	INBOUND	192.168.11.0/24 (local network)	7070	OPEN	MEDIUM	Port 7070 tcp open ssl/realserver — SSL service on non-standard port. Should be audited to confirm legitimate use.
192.168.11.2 — DNS Server (dnsmasq)	INBOUND	192.168.11.0/24 (local network)	53	OPEN	LOW	Port 53/tcp open — DNS service running dnsmasq. Normal and expected on local network. Low risk as restricted to local subnet.
GCP Equivalent — dangerous-ssh-open rule	INGRESS	0.0.0.0/0 (entire internet)	22	ALLOW	CRITICAL	SSH open to entire internet — enables automated brute force attacks. 231 attacks observed in Linux Log Analysis project within hours.
GCP Equivalent — default-allow-rdp rule	INGRESS	0.0.0.0/0 (entire internet)	3389	ALLOW	CRITICAL	RDP open to entire internet — primary attack vector for ransomware delivery and lateral movement into Windows systems.
GCP Equivalent — secure-ssh-restricted rule	INGRESS	YOUR_IP/32 (single known IP)	22	ALLOW	LOW	SSH restricted to single known IP only — secure configuration. Only authorised administrator can connect.

CRITICAL FINDING: Any firewall rule with Source Range 0.0.0.0/0 and Port 22 (SSH) or Port 3389 (RDP) is a critical misconfiguration. It means anyone in the world can attempt to brute force login — this is exactly what happened in the Linux Log Analysis project where 231 attacks came from external IPs.

5. PART 3 — SECURITY COMMAND CENTER AUDIT

Google Security Command Center (SCC) is GCP's built-in security dashboard that automatically scans projects and reports misconfigurations, vulnerabilities, and threats. In this audit, flaws.cloud levels 4–6 were used as the SCC equivalent — each level demonstrates a real cloud security vulnerability of the type SCC detects and reports.

5.1 Finding 4 — Instance Metadata Credential Exposure (Level 4)

What was found: Cloud instances (EC2 on AWS, GCE on GCP) expose a metadata service endpoint at a fixed internal IP address. If not properly restricted, this endpoint returns temporary IAM credentials to anyone with access to the instance. A compromised application running on the instance can steal these credentials and use them to access all cloud resources the instance role has access to.

Figure 7 — flaws.cloud Level 4 Hint 2: EC2 snapshot publicly accessible — instance metadata and storage exposure

```
sudo file -s /dev/xvdb1

# Returns:
# /dev/xvdb1: Linux rev 1.0 ext4 filesystem data, UUID=5a2075d0-d095-4511-bef9-802fd8a7610e, volume name
"cloudimg-rootfs" (extents) (large files) (huge files)

# Next we mount it

sudo mount /dev/xvdb1 /mnt

Now you can dig around in that snapshot. Need more help? See Hint 3
```

Figure 8 — Level 4 continued: Mounting exposed snapshot reveals sensitive filesystem data

5.2 Finding 5 — SSRF via Instance Metadata Endpoint (Level 5)

What was found: Level 5 demonstrated a Server-Side Request Forgery (SSRF) attack against the EC2/GCE instance metadata endpoint at 169.254.169.254. By exploiting a misconfigured proxy, the attacker was able to reach the internal metadata service and retrieve temporary IAM security credentials — identical to what GCP's Security Command Center flags as a High severity SSRF/metadata exposure finding.



Figure 9 — flaws.cloud Level 5 Hint 2: SSRF via proxy reaching metadata endpoint 169.254.169.254 returning IAM credentials

5.3 Finding 6 — Privilege Escalation via Lambda and API Gateway (Level 6)

What was found: Level 6 demonstrated privilege escalation using overpermissioned IAM roles attached to Lambda functions via API Gateway. The SecurityAudit policy allowed enumeration of Lambda functions and their attached policies, revealing an execute permission that granted full API access — identical to the IAM privilege escalation chain that GCP SCC flags as Critical.

Level 6: Hint 2

You now know that you have the ability to GET "arn:aws:apigateway:us-west-2::/restapis/*"

The API gateway in this case is used to call a lambda function, but you need to figure out how to invoke it.

The SecurityAudit policy lets you see some things about lambdas:

```
aws --region us-west-2 --profile level6 lambda list-functions
```

That tells you there is a function named "Level6", and the SecurityAudit also lets you run:

```
aws --region us-west-2 --profile level6 lambda get-policy --function-name Level6
```

This tells you about the ability to execute "arn:aws:execute-api:us-west-2:975426262029:s33ppypa75/*GET/level6\` That "s33ppypa75" is a rest-api-id, which you can then use with that other attached policy:

```
aws --profile level6 --region us-west-2 apigateway get-stages --rest-api-id "s33ppypa75"
```

That tells you the stage name is "Prod". Lambda functions are called using that rest-api-id, stage name, region, and resource as <https://s33ppypa75.execute-api.us-west-2.amazonaws.com/Prod/level6>

Visit that URL.

Figure 10 — flaws.cloud Level 6 Hint 2: Privilege escalation via overpermissioned Lambda IAM role and API Gateway

5.4 SCC Findings Summary

#	Finding Name	Category	Severity	What It Means	Resource Affected	Status
1	Public Storage Bucket — allUsers Read Access	Storage	CRITICAL	Anyone on the internet can list and download all files in the bucket without any login or credentials	flaws.cloud bucket (Level 1)	Documented — Fix: set bucket to private
2	Overpermissioned IAM Policy — AuthenticatedUsers Access	IAM	CRITICAL	IAM policy grants resource access to all 1M+ authenticated AWS/GCP users instead of specific service accounts	flaws.cloud Level 2 bucket	Documented — Fix: restrict to specific principals
3	Credentials Exposed in Git History	IAM / Secrets	CRITICAL	AWS IAM access keys committed to git repository — recoverable from commit history even after deletion from code	flaws.cloud Level 3 git repo	Documented — Fix: rotate keys, use Secrets Manager

4	Instance Metadata Service Credential Exposure	Compute / IAM	HIGH	EC2/GCE instance metadata endpoint returns temporary IAM credentials — accessible from inside compromised instance	flaws.cloud Level 4 EC2 instance	Documented — Fix: restrict metadata access
5	Privilege Escalation via IAM Role Chaining	IAM	HIGH	Low-privilege IAM role can assume a higher-privilege role — attacker can escalate from limited access to admin access	flaws.cloud Level 5–6	Documented — Fix: audit role trust policies

6. COMPLETE FINDINGS SUMMARY

This table consolidates all findings from all three audit areas into a single prioritised remediation list:

Priority	Finding	Audit Area	Severity	Risk if Not Fixed	Fix Applied
P1	Public S3/GCS bucket — allUsers read access without authentication	IAM / Storage	CRITICAL	Full data breach — all files readable by anyone. Compliance violation (GDPR, PCI-DSS).	Documented. Fix: remove allUsers, set bucket private, grant only specific service accounts.
P2	Overpermissioned IAM policy — 1M+ AWS accounts granted access	IAM	CRITICAL	Any compromised AWS account can access resources. Authentication does not equal authorisation.	Documented. Fix: restrict policy to specific account ARNs / service account emails only.
P3	IAM credentials exposed in git commit history	IAM / Secrets	CRITICAL	Full account takeover. Keys usable immediately for data exfiltration, resource deletion, backdoor creation.	Documented. Fix: rotate keys immediately, use Secret Manager, enable git-secrets hooks.

P4	SSH Port 22 open to 0.0.0.0/0 (entire internet)	Firewall	CRITICAL	Automated brute force attack possible from anywhere worldwide — 231 attacks observed within hours in real environment.	Fix: delete rule. Create restricted rule with --source-ranges YOUR_IP/32 only.
P5	RDP Port 3389 open to 0.0.0.0/0 (entire internet)	Firewall	CRITICAL	Primary ransomware delivery vector. RDP exploitation used in 90% of ransomware attacks on cloud VMs.	Fix: disable RDP to internet entirely. Use VPN or IAP (Identity-Aware Proxy) for remote access.
P6	Instance metadata service exposing temporary IAM credentials	Compute / IAM	HIGH	Compromised app on instance can steal credentials and pivot to other cloud resources.	Fix: restrict metadata endpoint. Use Workload Identity instead of instance-level credentials.
P7	IAM privilege escalation via role chaining	IAM	HIGH	Low-privilege attacker escalates to admin access. Bypasses access control entirely.	Fix: audit all role trust policies. Remove unnecessary AssumeRole / impersonation permissions.

7. REMEDIATION STEPS PERFORMED

7.1 IAM Fixes

- Identified and documented all three classes of IAM misconfiguration: public access, overpermissioned policies, and credential exposure
- Confirmed that public bucket access (allUsers) should be removed and replaced with specific service account grants using roles/storage.objectViewer
- Documented that IAM policies must restrict access to specific principal identifiers — never to allAuthenticatedUsers or wildcard ARNs
- Confirmed that any credentials exposed in git history must be rotated immediately and Secret Manager must be used for all future credential storage
- Verified that pre-commit hooks (git-secrets) should be enabled to prevent future credential commits

7.2 Firewall Fixes

- Identified all firewall rules with source range 0.0.0.0/0 as critical misconfigurations requiring immediate remediation
- Documented the dangerous-ssh-open scenario and the correct remediation: delete the rule and create a restricted replacement
- Confirmed that RDP (port 3389) should never be exposed to the internet — VPN or Identity-Aware Proxy should be used instead
- Documented the secure-ssh-restricted rule pattern: restrict SSH to a specific /32 IP address of the administrator only

```
# GCP commands to remediate firewall misconfigurations:
gcloud compute firewall-rules delete dangerous-ssh-open

# Create secure restricted SSH rule
gcloud compute firewall-rules create secure-ssh-restricted \
  --allow tcp:22 \
  --source-ranges YOUR_IP_ADDRESS/32 \
  --description 'Secure SSH - restricted to known IP only'

# Verify - confirm 0.0.0.0/0 rules are removed
gcloud compute firewall-rules list
```

7.3 SCC Finding Fixes

- Documented instance metadata credential exposure — fix: restrict IMDS access, migrate to Workload Identity Federation
- Documented privilege escalation via role chaining — fix: audit all IAM role trust policies, remove unnecessary AssumeRole permissions
- Documented attack chain from Level 6 — fix: apply defence in depth, each layer of access should require independent authentication
- Enabled understanding of how individual findings compound — a single exposed credential + overpermissioned role = full account takeover

8. MITRE ATT&CK MAPPING

The misconfigurations found in this audit map to the following MITRE ATT&CK Cloud attack techniques. This mapping is used by SOC teams globally to classify incidents, prioritise responses, and align with threat intelligence:

Misconfiguration Found	MITRE Technique	ID	How Attacker Exploits It
Public S3/GCS bucket — allUsers access	Data from Cloud Storage	T1530	Attacker reads sensitive files, API keys, and config secrets stored in

Overpermissioned IAM policy — AuthenticatedUsers	Valid Accounts — Cloud Accounts	T1078.004	bucket without any authentication required Any compromised AWS/GCP account gains access to resources — attacker purchases stolen credentials and immediately accesses data
IAM credentials in git history	Unsecured Credentials — Credentials in Files	T1552.001	Attacker scans public GitHub/GitLab repos for accidentally committed keys — automated tools scan millions of repos daily
SSH port 22 open to 0.0.0.0/0	Brute Force — Password Spraying	T1110.003	Automated tools attempt thousands of password combinations per minute against open SSH port — no rate limiting possible
RDP port 3389 open to 0.0.0.0/0	Exploit Public-Facing Application	T1190	Attacker exploits RDP vulnerabilities (BlueKeep, DejaBlue) or brute-forces credentials to gain Windows system access for ransomware
Instance metadata credential exposure	Steal Application Access Token	T1528	Compromised application calls metadata endpoint to retrieve temporary IAM credentials — pivots to all resources the instance role can access
IAM privilege escalation via role chaining	Abuse Elevation Control Mechanism	T1548	Low-privilege attacker assumes higher-privilege role through AssumeRole chaining — bypasses access controls to reach admin permissions
Disabled or missing audit logging	Impair Defences — Disable Cloud Logs	T1562.008	Attacker disables Cloud Audit Logs / CloudTrail to cover tracks — incident response becomes impossible without audit trail

9. SOC & CLOUD ANALYST RELEVANCE

Skill Practised in This Audit	How It Applies in a Real Cloud Security Role
Cloud IAM misconfiguration analysis	Cloud Security Analysts audit IAM policies weekly to detect privilege creep. Identifying public bucket access and overpermissioned policies is a core daily task in GCP/AWS security roles
Credential exposure detection	Security engineers scan git repositories and code for leaked credentials. Tools like truffleHog and git-secrets automate this in CI/CD pipelines — understanding the vulnerability is prerequisite

Network port scanning with Nmap	SOC analysts use Nmap to verify firewall rules are correctly applied after deployments. Nmap is listed in job descriptions for Cloud Security Engineer and Penetration Tester roles
Cloud security scanner operation	SCC (GCP), GuardDuty (AWS), and Defender for Cloud (Azure) are the primary tools cloud security teams use for automated threat detection — flaws.cloud teaches the underlying vulnerability classes
Severity rating and prioritisation	Cloud analysts rate findings Critical/High/Medium/Low to prioritise remediation effort and communicate risk to engineering teams — same framework applied in this report
MITRE ATT&CK mapping	All cloud incidents are classified using MITRE for SOC reporting, threat intelligence sharing, and detection rule writing — mandatory skill for Cloud Security Analyst and SOC Analyst roles
Remediation documentation	Every fix must be documented with before/after evidence and verified — analysts re-run checks after remediation and produce remediation reports identical in structure to this one

10. LESSONS LEARNED

What surprised me most: I was surprised by how simple the Level 1 misconfiguration was — just opening the bucket URL in a browser returned a full list of every file including a secret file. No hacking tools, no special skills required. A single checkbox in the wrong position in a cloud console exposes an entire organisation's data to the entire internet. This made me realise that cloud security is not just about sophisticated attacks — it is about preventing simple configuration mistakes.

What I understood about cloud security: Before this project I understood cloud security as a theoretical concept. After completing all 6 levels of flaws.cloud, I now understand that IAM misconfigurations compound — the Level 6 attack chain showed how a public bucket leads to exposed git credentials, which leads to an IAM role, which leads to full account access. Defence in depth means each layer must independently enforce access controls, not rely on other layers to compensate.

Connection to Google Cloud Cybersecurity Certificate: The Google Cloud Cybersecurity Certificate taught me the concepts of IAM, VPC firewall rules, and Security Command Center. This hands-on project made those concepts concrete — I could see exactly what a public bucket misconfiguration looks like in practice, how overpermissioned IAM policies are exploited, and why the principle of least privilege is the most important security principle in cloud environments. The MITRE ATT&CK mapping section connected my GCP knowledge to the broader security industry framework used in SOC roles.